

Home > Threats and vulnerabilities

DEFINITION

Common Vulnerability Scoring System (CVSS)

By [Alexander S. Gillis](#), Technical Writer and Editor | [Madelyn Bacon](#), TechTarget

What is the Common Vulnerability Scoring System (CVSS)?

The Common Vulnerability Scoring System (CVSS) is a public [framework](#) for rating the severity of security vulnerabilities in software. It's application- and vendor-neutral, enabling an organization to score its IT vulnerabilities across a wide range of software products -- from operating systems and databases to web applications -- using the same scoring framework.

The CVSS framework is maintained by the Forum of Incident Response and Security Teams (FIRST), a nonprofit organization consisting of more than 500 members.

IT managers, [information security](#) teams, application vendors and security vendors can use this method to prioritize security tests or to ensure that known vulnerabilities are removed during development. CVSS has been adopted by organizations, industries and government groups, such as the Department of Homeland Security's (DHS) [Cybersecurity and Infrastructure Security Agency](#). Vendors such as Cisco, Qualys, Oracle and SAP also generate CVSS scores to communicate the severity of vulnerabilities found in their products.

CVSS scores are calculated using a formula consisting of vulnerability-based metrics. A CVSS score is derived from scores in these three groups: Base, Temporal and Environmental. Scores range from zero to 10, with zero representing the least severe and 10 representing the most severe.

Why do organizations adopt CVSS?

Historically, vendors used their own methods for scoring software vulnerabilities, often without detailing how their scores were calculated. This created a conundrum for systems admins: Should they fix a vulnerability with a severity of *high* first or one with a rating of five?

To address this problem, CVSS simplifies the generation of consistent scores that reflect the severity and impact of vulnerabilities in an IT environment. CVSS also provides the following:

- **Establishes an open framework.** Organizations have full access to the CVSS parameters used to generate scores, providing everyone the ability to calculate scores consistently.
- **Mitigates vulnerabilities in development.** Software developers can use CVSS scores to prioritize security tests and ensure known and serious vulnerabilities are removed or mitigated during development.
- **Meets security standards.** CVSS can help organizations meet the security requirements of various standards. For example, the presence of unpatched vulnerabilities with a CVSS score of four or higher has an adverse effect on [Payment Card Industry Data Security Standard compliance](#).

History of CVSS

The U.S. National Infrastructure Advisory Council (NIAC) first introduced CVSS in 2005, but FIRST now owns and manages it. NIAC developed CVSS to simplify the generation of consistent scores that could accurately reflect the existing risks and vulnerabilities to a specific IT environment.

FIRST sponsors and supports the CVSS Special Interest Group (SIG), which is made up of various organizations and individuals who help promote and refine the framework.



Security



The CVSS SIG provided most of the research and feedback on the initial design of CVSS and helped test and refine the formulas used in later versions.

CVSS v2 was released in 2007 and was seen as a significant improvement over the original version. It had fewer inconsistencies, provided additional granularity and more accurately reflected the true properties of IT vulnerabilities, despite the wide variety of vulnerability types.

CVSS 3.0, released in June 2015, introduced scoring changes that more accurately reflected the reality of vulnerabilities encountered in the wild. For example, the update introduced changes such as the privileges required to exploit a vulnerability and the opportunities it gives an attacker who successfully uses it.

The [most recent version](#) of CVSS is version 3.1, released in June 2019. The changes in this version focus on clarifying and improving the standard. This version doesn't create any new metrics or metric values and doesn't make major changes to the formulas.

Updates to this version of CVSS include the following:

- Attack and modified [attack vector](#) changes.
- Changes to the guidance provided for environmental security requirements metrics.
- CVSS base score changes.
- Scoring now based on gained privileges instead of attained privileges.
- Scoring guidance changes.
- Scoring based on detailed data.
- Scoring vulnerabilities in software libraries.

Vulnerability metrics

A CVSS score is derived from scores in the Base, Temporal and Environmental groups. Together, these groups cover the different characteristics of a vulnerability, including its impact and environmental endurance over time.

Base metrics

The Base score is the metric enterprises rely upon most. IT deals with the inherent characteristics of a vulnerability -- that is, the ones that don't change over time or due to a user's environment. It's made up of the following two sets of metrics:

1. Exploitability metrics, which include the following:

- Attack Vector.
- Attack Complexity.
- Privileges Required.
- User Interaction.

2. Impact metrics, which include the following:

- Confidentiality Impact.
- Integrity Impact.
- Availability Impact.

Temporal metrics

The Temporal score measures aspects of the vulnerability according to its current status. It represents properties of a vulnerability that can change over time, such as the release of an official patch.

Temporal scoring also includes the Report Confidence metric, which measures the following:

- The degree of confidence in the existence of the vulnerability.

- The credibility of the known technical details demonstrating that a vulnerability is both real and exploitable.

These metrics can decrease or increase the Base score -- for example, if a patch or workaround becomes available or the vendor validates a vulnerability.

Temporal values include the following:

- Exploit Code Maturity.
- Remediation Level.
- Report Confidence.

Environmental metrics

The CVSS system's Environmental metrics let an organization refine the Base score to reflect its own environment by measuring the severity of the vulnerability. This score can be adjusted for its impact on individual systems.

Environmental metrics provide real context for vulnerabilities within an organization by considering the following factors:

- Business criticality of the asset.
- Identification of mitigating controls.
- Use of the asset in question.

The entire list of Environmental metric categories consists of the following:

- Collateral Damage Potential.
- Target Distribution.
- Confidentiality Requirement.
- Integrity Requirement.
- Availability Requirement.

How CVSS scoring works



How CVSS scoring works

A CVSS score can be between zero and 10, with 10 being the most severe. To help convey CVSS scores to less technical stakeholders, FIRST maps CVSS scores to the qualitative ratings in the figure here.

The Base score is mandatory, while the Temporal score is optional. Both are provided by the vendor or analyst. The end user calculates the Environmental group score, which is also optional.

The only requirement for categorizing a vulnerability with a CVSS score is the completion of the Base score components: the Exploitability subscore, the Impact subscore and the Scope subscore. These scores are used to calculate the overall Base score using a formula that weights each subscore.

The Temporal score is calculated by multiplying the Base score by the three



In the CVSS framework, higher scores correspond to more severe vulnerabilities.

metrics within the Temporal metric.

The Environmental score is a more complex calculation. The end user recomputes the Base and Temporal scores using the five Environmental metrics to give a more accurate evaluation of the severity of a vulnerability.

CVSS vs. CVE

Common Vulnerabilities and Exposures ([CVE](#)) is a catalog of known security threats. CVE divides threats into two categories: vulnerabilities and exposures. The catalog, which is sponsored by DHS, is designed to standardize the way each known vulnerability or exposure is identified.

While CVE is a list of all disclosed vulnerabilities, CVSS is an overall score assigned to a vulnerability. CVSS isn't a vulnerability classification scheme like the CVE system, which assigns each vulnerability a unique identifier, as listed in the National Institute of Standards and Technology (NIST) National Vulnerability Database.

CVE identifiers are formatted as follows:

CVE-[Four-Digit Year]-[Sequential Identifier]

For example, the CVE identifier for the [Heartbleed](#) vulnerability is CVE-2014-0160, and the CVE identifier for the Log4j 2 vulnerability is CVE-2021-44228.

CVE uses CVSS to provide an indication of the severity of each CVE. For each CVE vulnerability, FIRST provides qualitative ratings based on the CVSS Base score.

CVSS calculators

A CVSS calculator is necessary to calculate the Temporal and Environmental scores for an organization's own environment. [FIRST](#), [NIST](#) and [Cisco](#) provide free CVSS calculators.

For example, FIRST's CVSS v3.1 calculator gives a score for each Base, Temporal and Environmental metric. To use the calculator, the end user selects one option from each provided category. For example, the Base score is calculated using metrics such as the following:

- **Attack Vector.** Network, adjacent, local or physical.
- **Attack Complexity.** Low or high.
- **Privileges Required.** None, low or high.
- **User Interaction.** None or required.
- **Scope.** Unchanged or changed.
- **Confidentiality.** None, low or high.
- **Integrity.** None, low or high.
- **Availability.** None, low or high.

Ultimate Guide to Cybersecurity for Businesses



Learn three additional steps for [ranking enterprise network security vulnerabilities](#).

This was last updated in April 2023

➤ Continue Reading About Common Vulnerability Scoring System (CVSS)

- [Security Think Tank: Core security processes must adapt in a complex landscape](#)
- [Compare vulnerability assessment vs. vulnerability management](#)
- [New vulnerability rating framework aims to fill in CVSS gaps](#)
- [How to mitigate Log4Shell, the Log4j vulnerability](#)
- [Vulnerability management vs. risk management, compared](#)

Related Terms

fraud detection

Fraud detection is a set of activities undertaken to prevent money or property from being obtained through false pretenses. [See complete definition](#) ⓘ

virus (computer virus)

A computer virus is a type of malware that attaches itself to a program or file. A virus can replicate and spread across an ... [See complete definition](#) ⓘ

virus signature (virus definition)

A virus signature, also known as a 'virus definition,' is a piece of code with a unique binary pattern that identifies a computer... [See complete definition](#)

➤ Dig Deeper on Threats and vulnerabilities

February Patch Tuesday corrects two Windows zero-days

By: Tom Walat

Threat actors targeting critical OwnCloud vulnerability

By: Arielle Waldman

November Patch Tuesday heralds five new MS zero-days

By: Alex Scroxton

Microsoft halts 3 zero-days on November Patch Tuesday

By: Tom Walat

-ADS BY GOOGLE

Latest TechTarget resources

NETWORKING

CIO

ENTERPRISE DESKTOP

CLOUD COMPUTING

COMPUTER WEEKLY

Networking

Why GenAI infrastructure optimization starts with the network

GenAI deployment requires optimized infrastructure. The networking aspects, such as workload placement and the type of deployment...

Cisco charts new security terrain with Hypershield

Initially, Hypershield protects software, VMs and containerized applications running on Linux. Cisco's ambition is to eventually ...

About Us	Definitions	Corporate Site
Editorial Ethics Policy	Guides	Contributors
Meet The Editors	Advertisers	Reprints
Contact Us	Partner with Us	Events
Videos	Media Kit	E-Products
Photo Stories		

All Rights Reserved, Copyright 2000 - 2024, TechTarget

[Privacy Policy](#)
[Do Not Sell or Share My Personal Information](#)